

# COS 433: Cryptography

## Announcements:

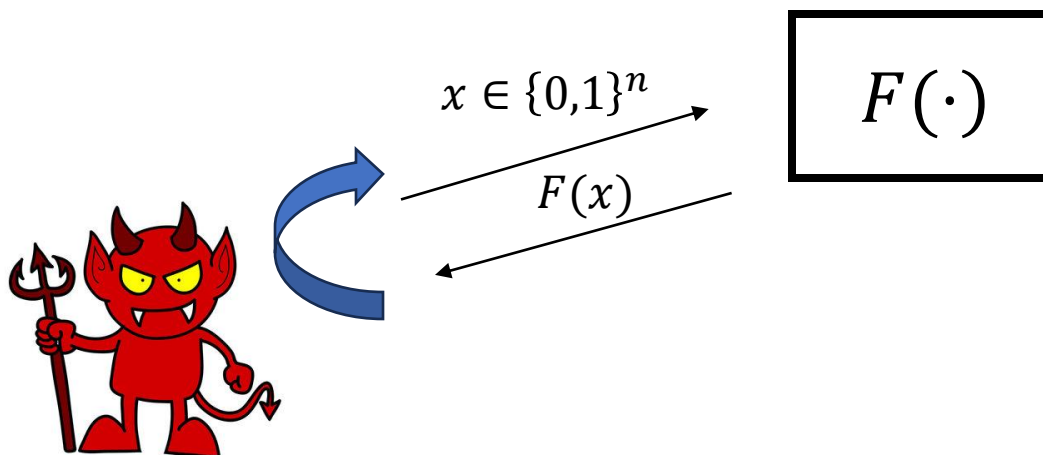
- Problem Set 2 is out, due October 8th.
- Problem Set 1 solutions will be released on Friday (after the late deadline)

Last time: PRPs

# Pseudorandom Permutations (PRPs)

**Definition:** An efficiently computable function family  $P: \{0,1\}^\lambda \times \{0,1\}^n \rightarrow \{0,1\}^n$  is a PRP family if:

1. **Invertibility:** there is an efficiently computable inverse map  $P^{-1}(s, \cdot)$  such that  $P^{-1}(s, P(s, x)) = x$  for all  $x$ .
2. For all polynomial-time  $A^{F(\cdot)}$ ,  $A^{P(s, \cdot)}(1^\lambda) \approx_c A^{P(\cdot)}(1^\lambda)$

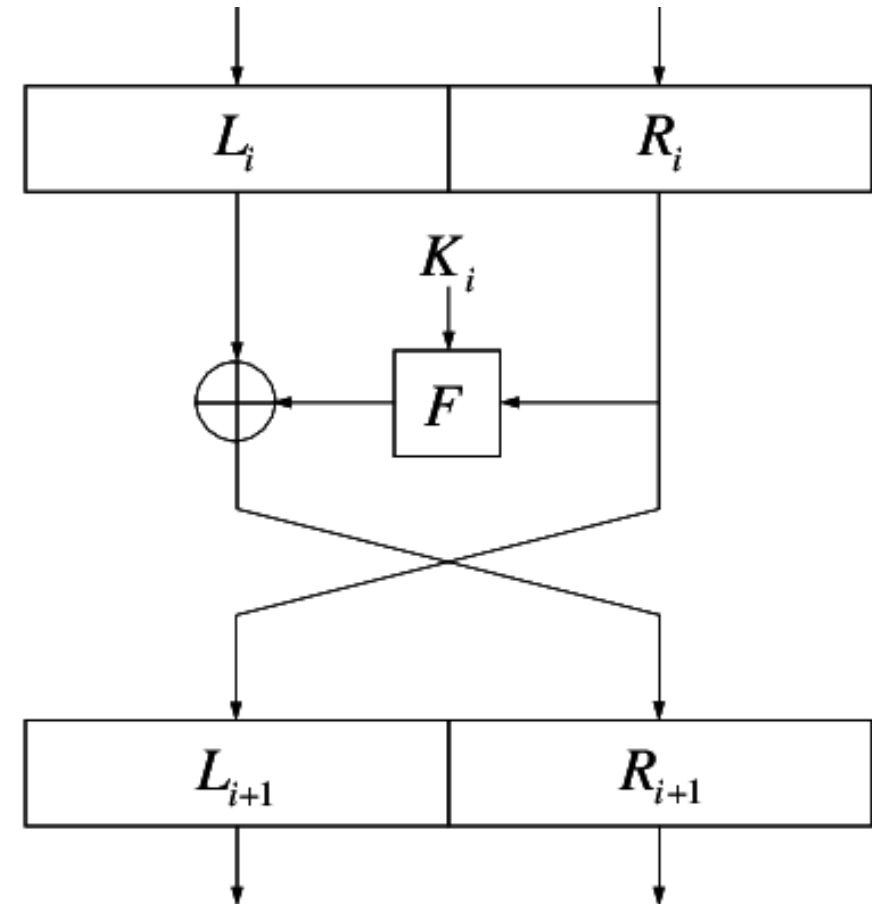


# Constructing PRPs

1. Theorem (Luby-Rackoff): if PRFs exist, then PRPs exist!
  - “Feistel Networks”
  - Related to the (heuristic) construction of DES.
2. Substitution-Permutation Networks (SPNs)
  - (heuristic) construction of AES.

# Feistel Networks

- $r$  rounds, “round keys”  $k_1, \dots, k_r$
- $F$ : “round function”
- Each round:  $F_{k_i}$ -gate, swap input halves.
- Luby-Rackoff:
  - $r = 3$
  - $F(\cdot, \cdot)$  = a PRF
  - i.i.d. round keys

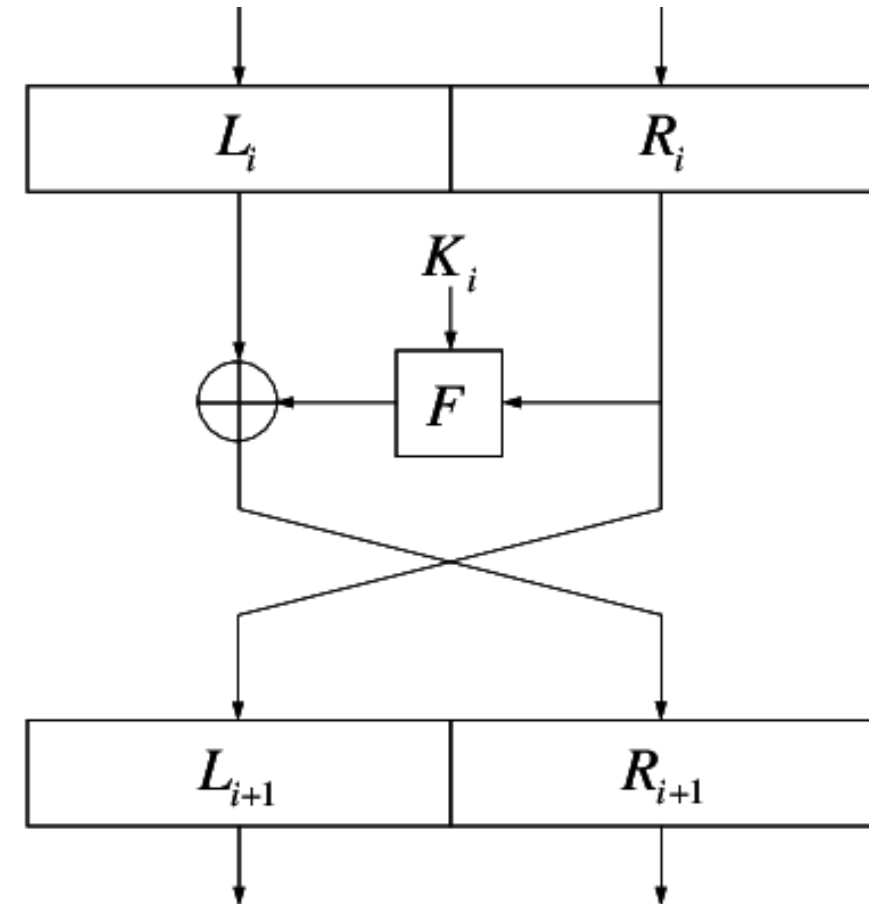
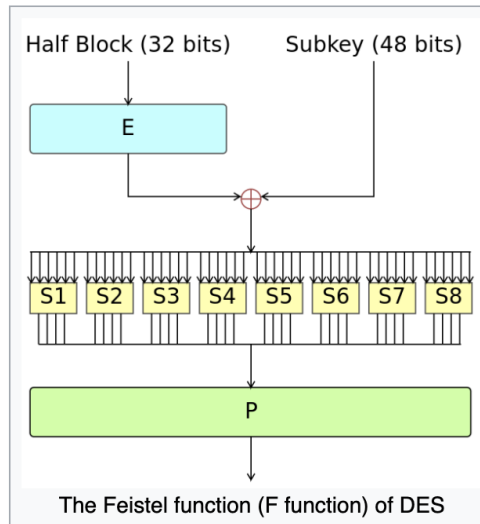


# Feistel Networks

- Two “sources” of security:
  - Security of each  $F_{k_i}$
  - Number of rounds  $r$

- DES block cipher:

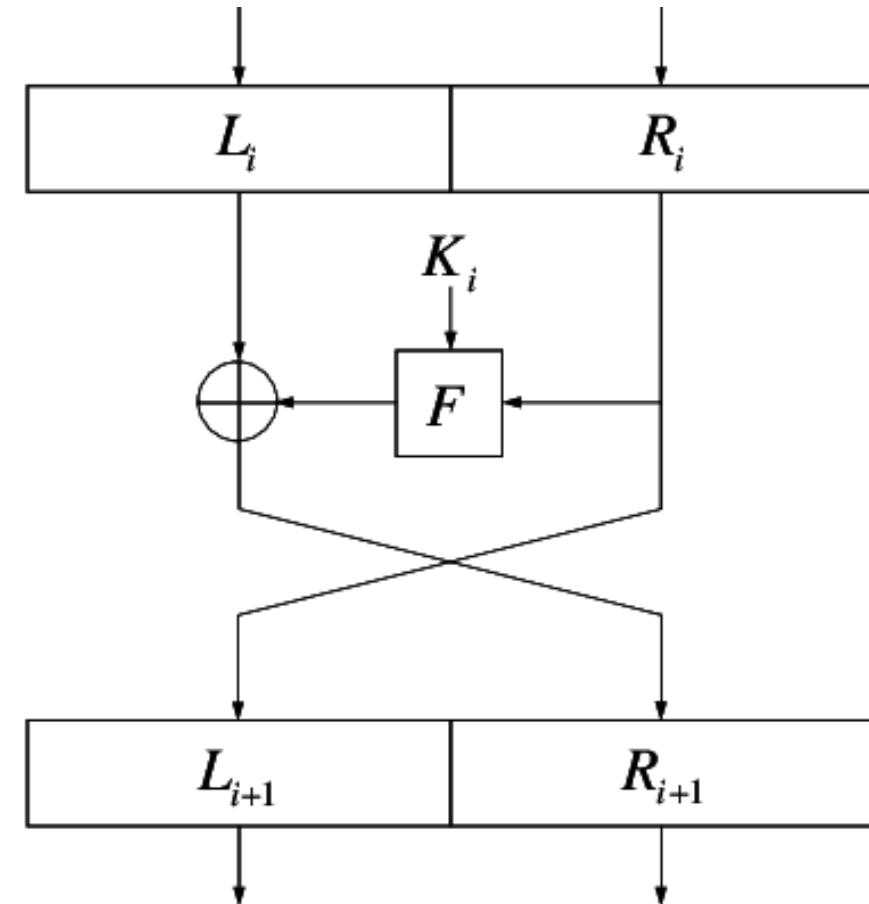
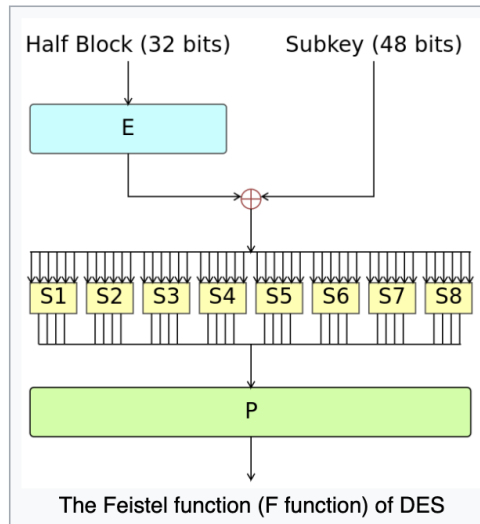
- $r = 16$
- $F_k =$
- round keys are **correlated** in order to minimize key length



# Feistel Networks

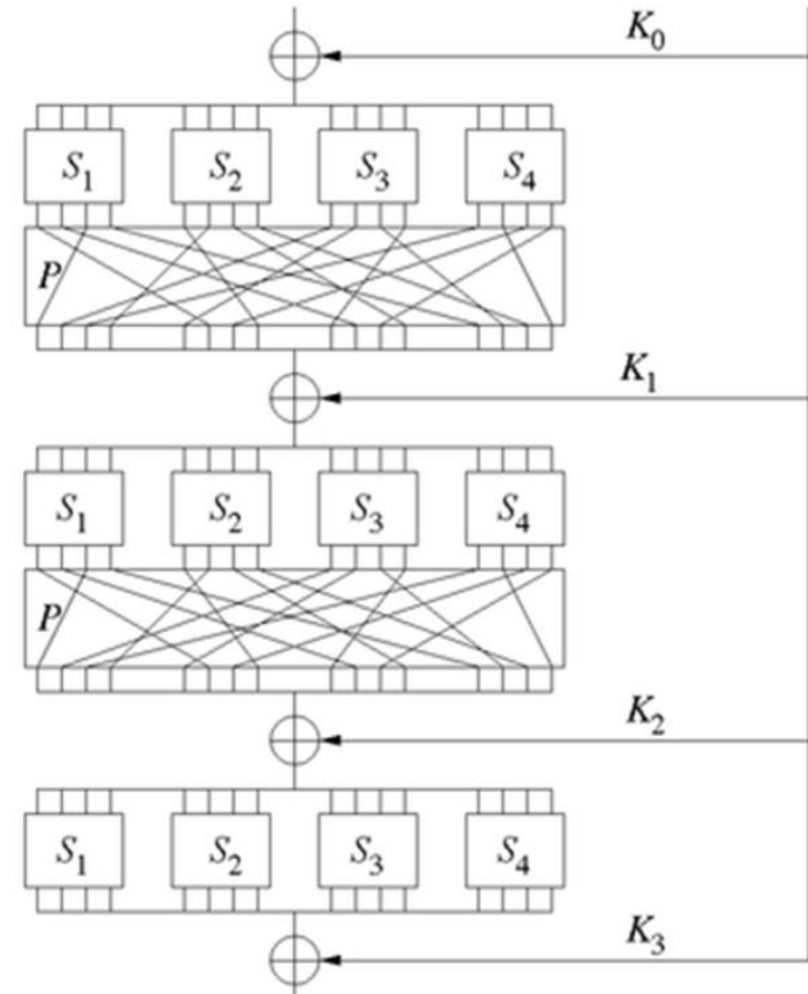
**Note:** DES keys too short (56 bits) to be secure in modern computing era

- DES block cipher:
  - $r = 16$
  - $F_k =$
  - round keys are **correlated** in order to minimize key length



# Substitution-Permutation Networks (AES)

- Similar to DES blueprint
- $r$  rounds, round keys  $k_i$  (AES:  $r = 10$ )
- Round function is a permutation to start with:
  - $S$ -box: highly non-linear **substitution** on sub-blocks
  - Linear **permutation**  $P$  on entire domain



**Hope (no proof):** each round scrambles more, eventually pseudorandom.



# Today: Authentication and CCA-security

What if

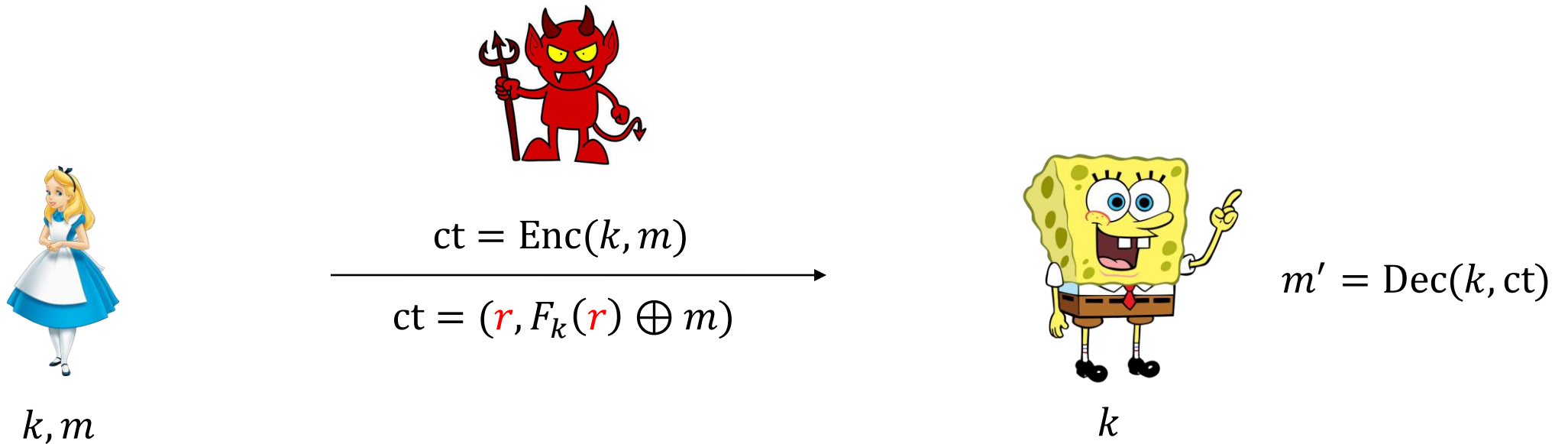


pretends to be



?

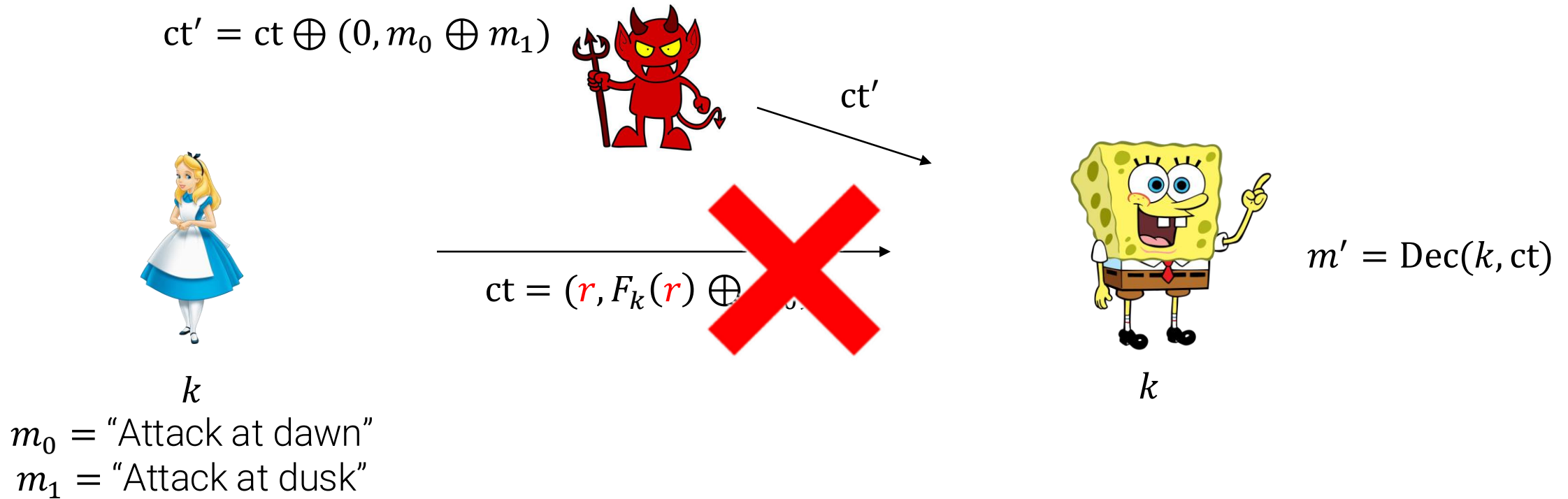
# Secret-Key Encryption



We know: this scheme is CPA-secure if  $F$  is a PRF family.

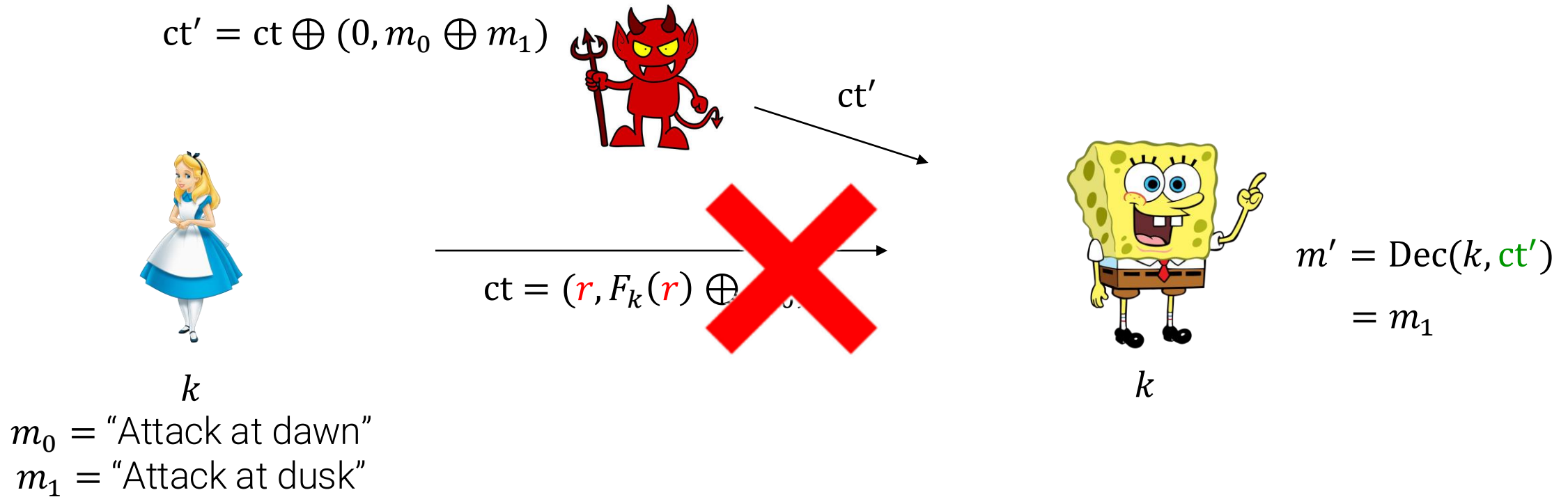
Is this secure enough to use in real life?

# Man in the Middle (MITM) Attacks



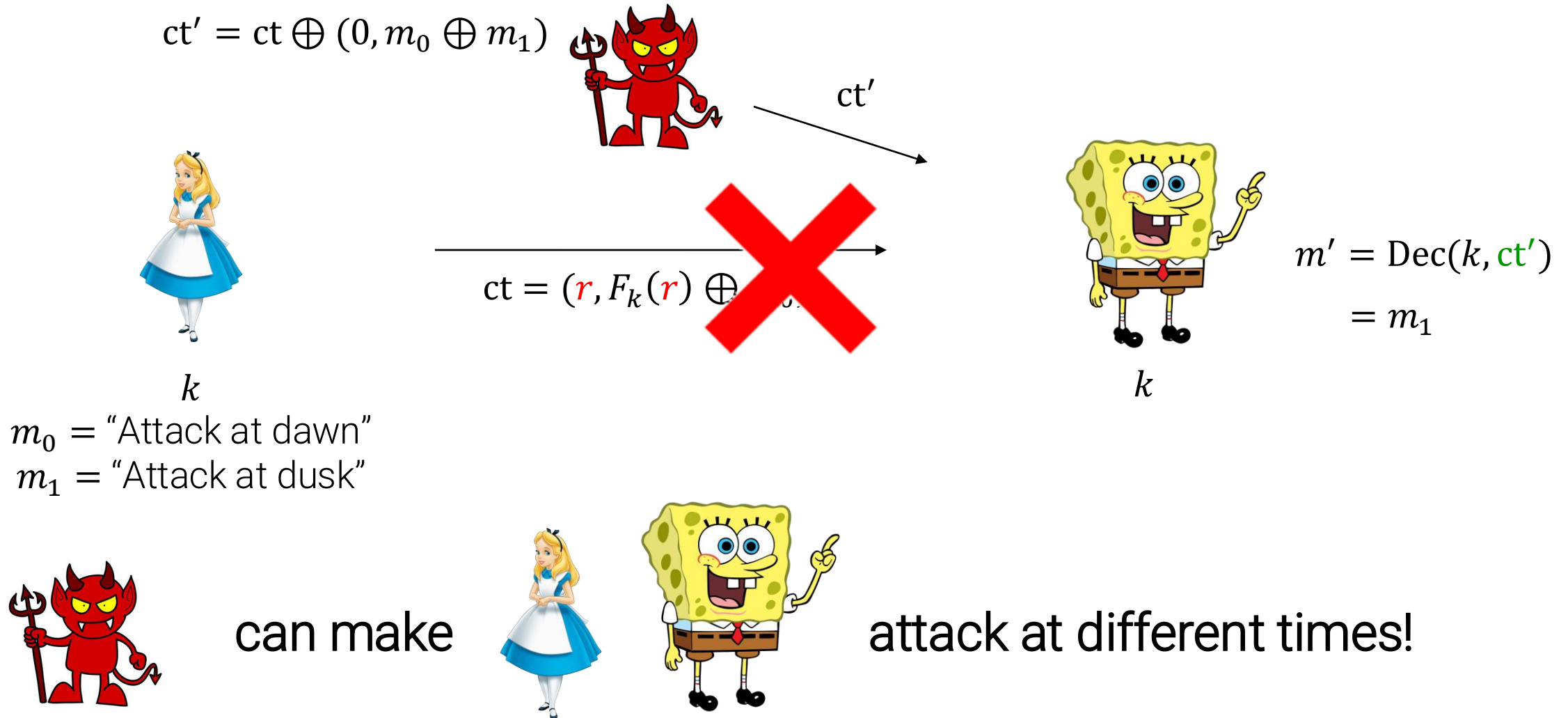
Is this secure enough to use in real life?

# Man in the Middle (MITM) Attacks

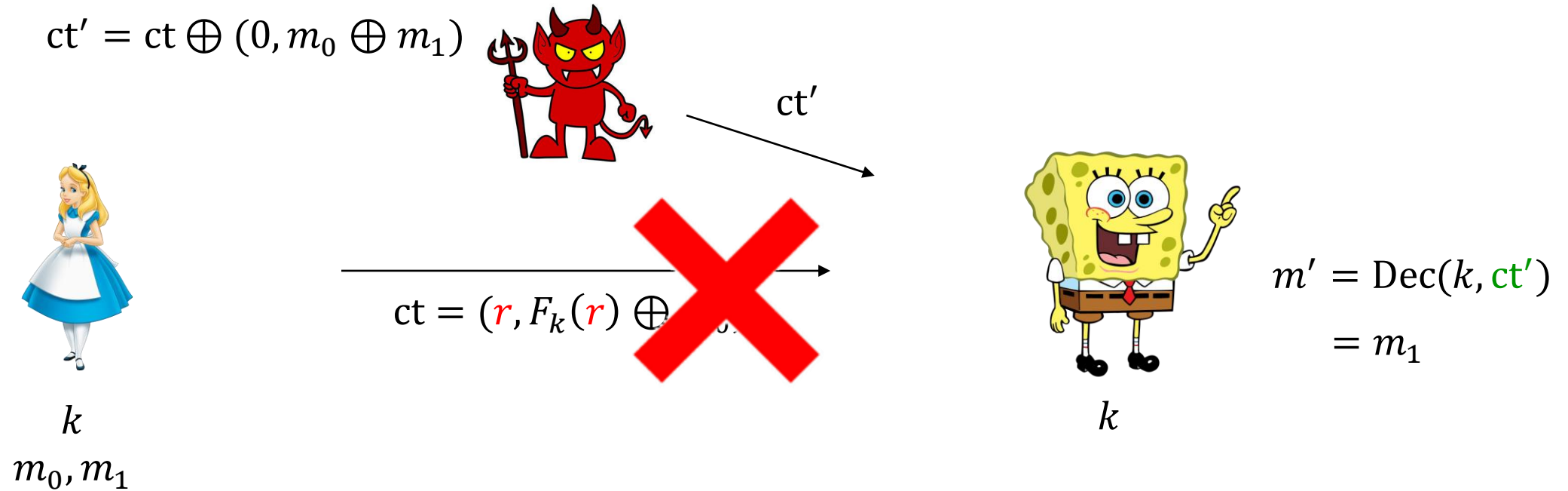


Is this secure enough to use in real life?

# Man in the Middle (MITM) Attacks

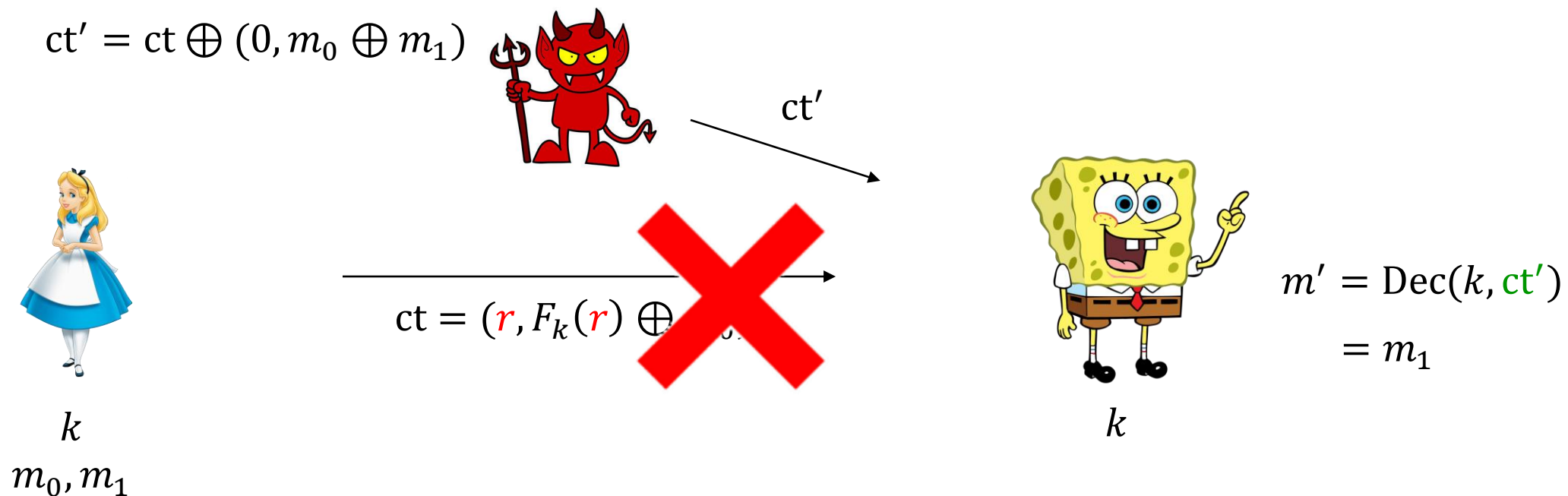


# Man in the Middle (MITM) Attacks



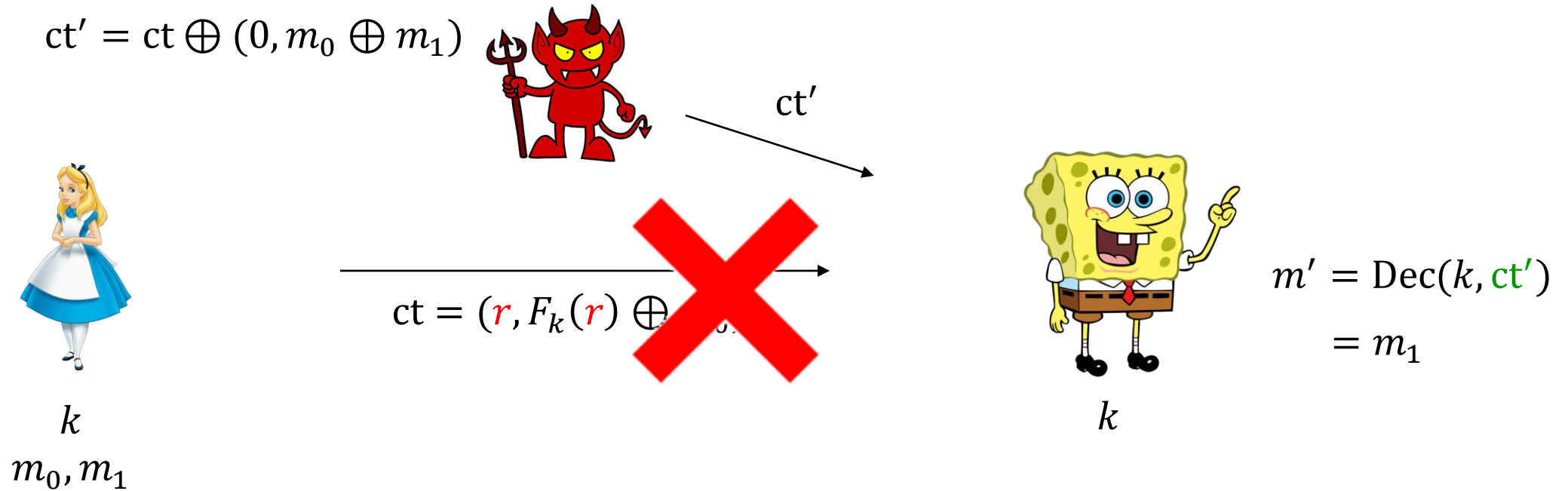
- **Problem:** how does  know that he is receiving a message from  ?
- We need a way to enforce **integrity** of the ciphertexts.

# Man in the Middle (MITM) Attacks



Philosophical question: is this scheme insecure?

# Man in the Middle (MITM) Attacks

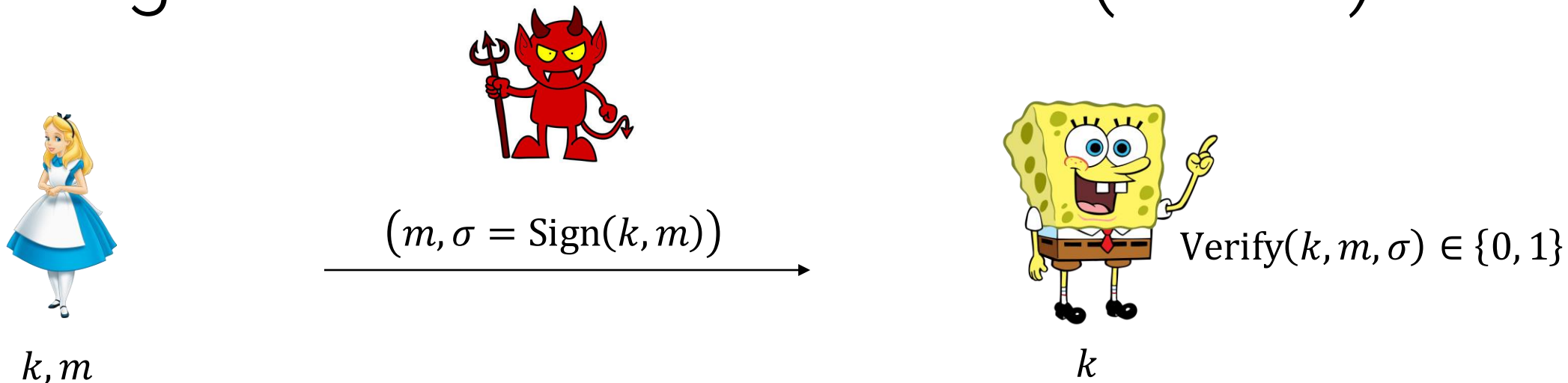


- **Answer #1:** No! It's CPA-secure! Integrity is an issue orthogonal to message privacy, and we shouldn't conflate them.
- **Answer #2:** Yes! **There is a way to view this as breaking a form of secrecy!**



Step 1: treat integrity as a standalone problem

# Message Authentication Codes (MACs)

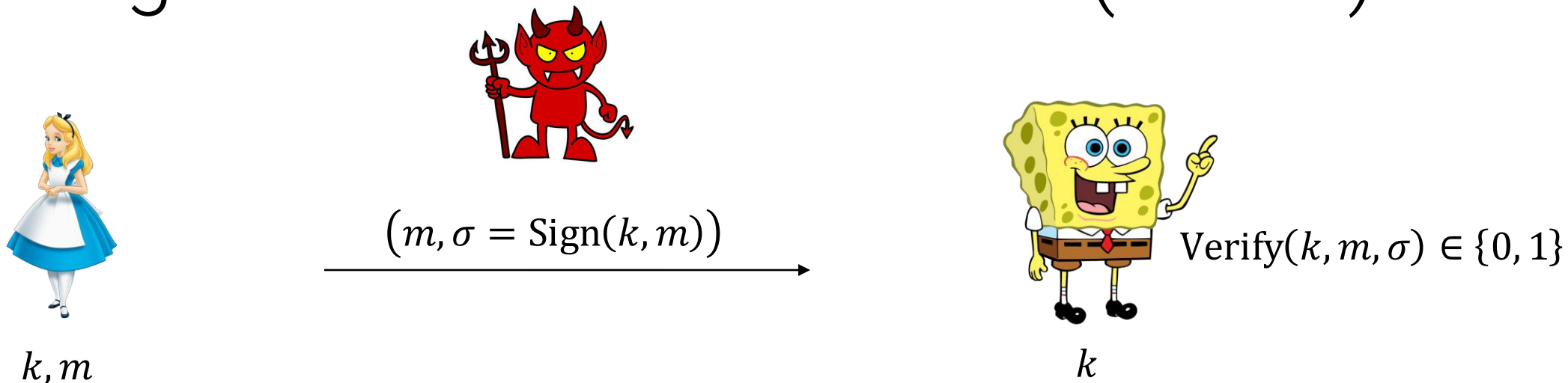


**Definition:** A **message authentication code (MAC)** scheme with message length  $n = n(\lambda)$  consists of efficient algorithms **Sign**, **Verify**. It must satisfy the following properties.

- **Correctness:** for all  $k, m$ ,  $\text{Verify}(k, m, \text{Sign}(k, m)) = 1$  with probability 1.
- **Unforgeability:** “an efficient MITM should not be able to send a fake message”

???

# Message Authentication Codes (MACs)

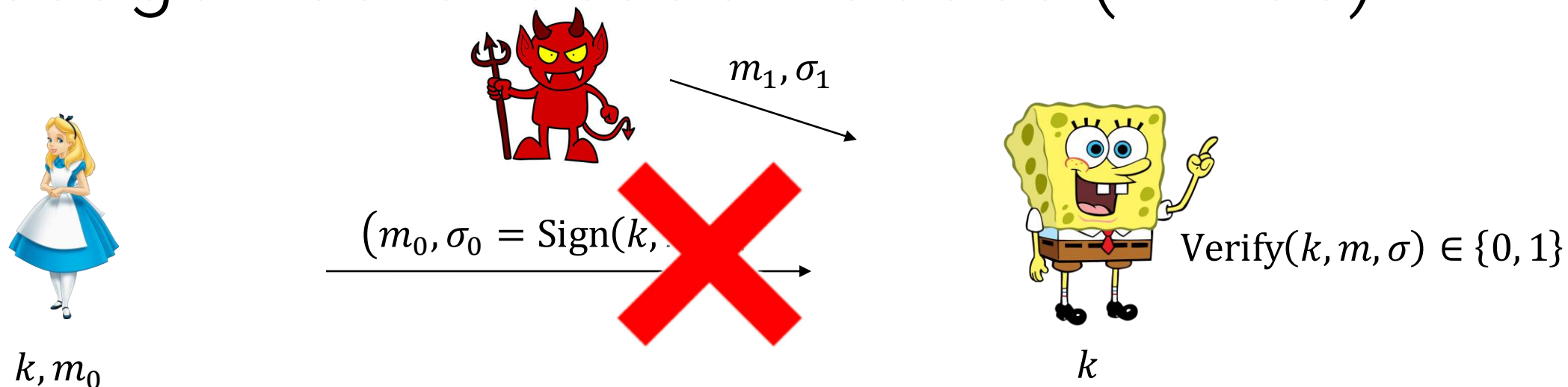


**Definition:** A **message authentication code (MAC)** scheme with message length  $n = n(\lambda)$  consists of efficient algorithms **Sign**, **Verify**. It must satisfy the following properties.

- **Correctness:** for all  $k, m$ ,  $\text{Verify}(k, m, \text{Sign}(k, m)) = 1$  with probability 1.
- **Unforgeability (attempt):** for all efficient  $A(m, \sigma) \rightarrow (m', \sigma')$  and all  $m_0 \neq m_1$  :

$$\Pr[A(m_0, \text{Sign}(k, m_0)) = (m_1, \sigma_1) : \text{Verify}(k, m_1, \sigma_1) = 1] = \text{negl}(\lambda)$$

# Message Authentication Codes (MACs)

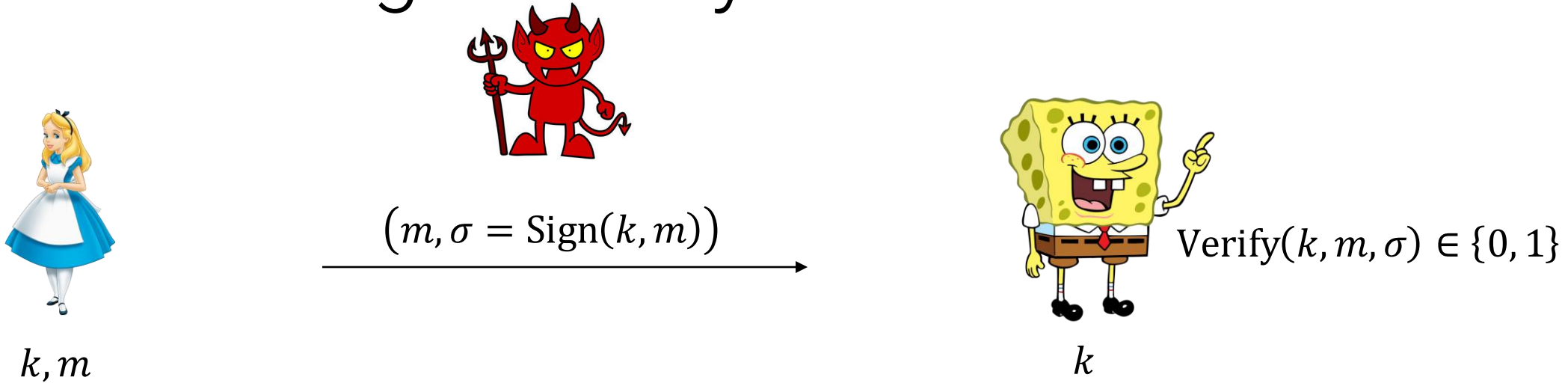


**Definition:** A **message authentication code (MAC)** scheme with message length  $n = n(\lambda)$  consists of efficient algorithms **Sign**, **Verify**. It must satisfy the following properties.

- **Correctness:** for all  $k, m$ ,  $\text{Verify}(k, m, \text{Sign}(k, m)) = 1$  with probability 1.
- **Unforgeability (attempt):** for all efficient  $A(m, \sigma) \rightarrow (m', \sigma')$  and all  $m_0 \neq m_1$ :

$$\Pr[A(m_0, \text{Sign}(k, m_0)) = (m_1, \sigma_1) : \text{Verify}(k, m_1, \sigma_1) = 1] = \text{negl}(\lambda)$$

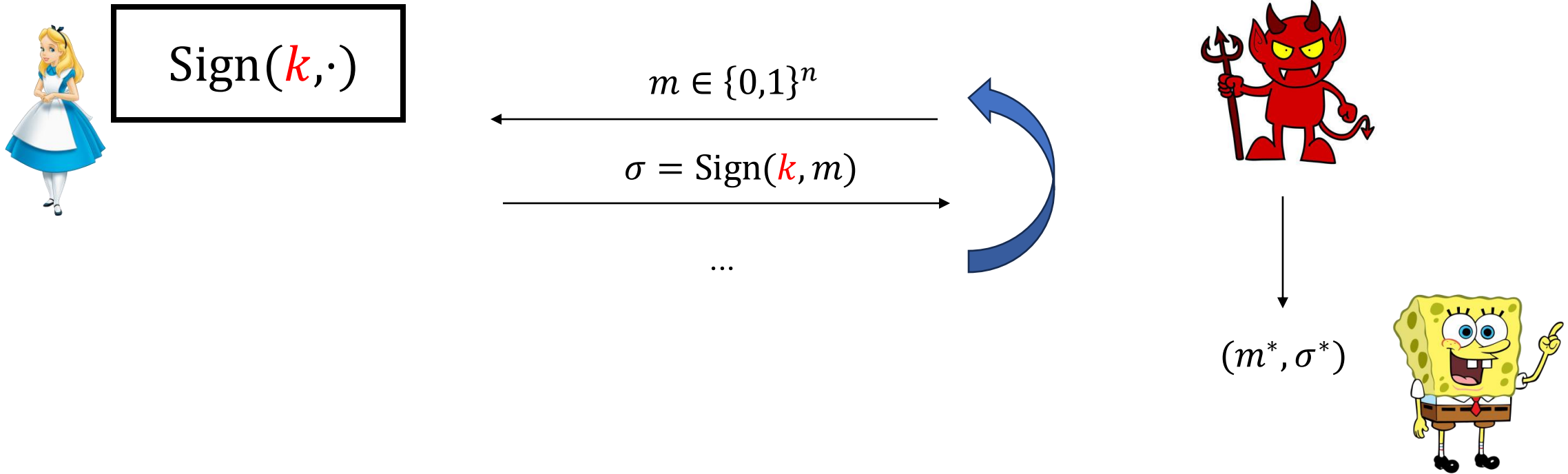
# Defining Security for MACs



## Attack Model:

-  can intercept messages (and prevent their delivery).
-  wants to trick  into accepting a message that  did not send.

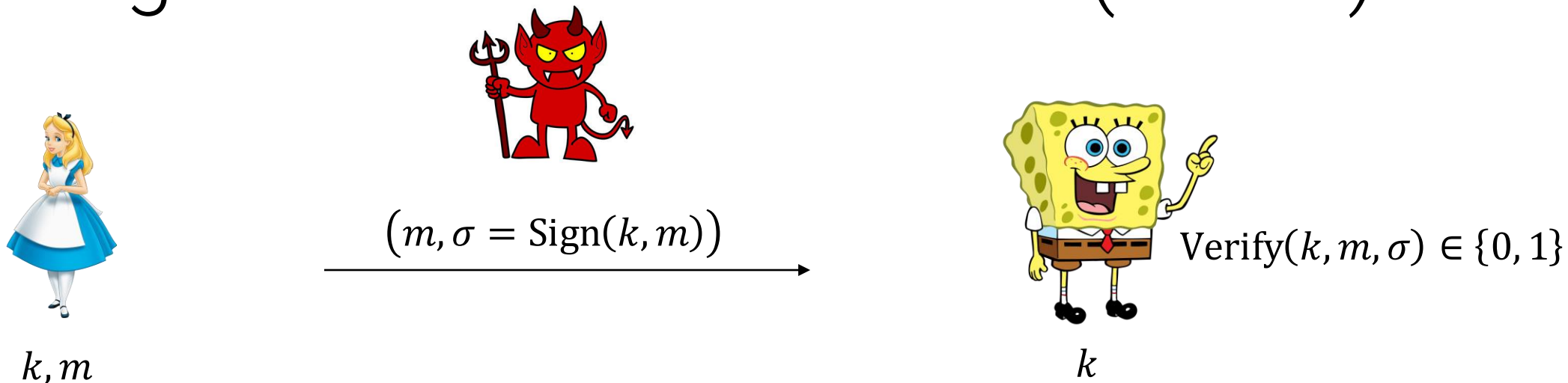
# Defining Security for MACs



Win if:

- $\text{Verify}(k, m^*, \sigma^*) = 1$ , and
- $m^*$  was not queried.

# Message Authentication Codes (MACs)



**Definition:** A **message authentication code (MAC)** scheme with message length  $n = n(\lambda)$  consists of efficient algorithms **Sign**, **Verify**. It must satisfy the following properties.

- **Correctness:** for all  $k, m$ ,  $\text{Verify}(k, m, \text{Sign}(k, m)) = 1$  with probability 1.
- **Unforgeability:** for all efficient oracle adversaries  $A^{\text{Sign}(\textcolor{red}{k}, \cdot)}$ , we have:

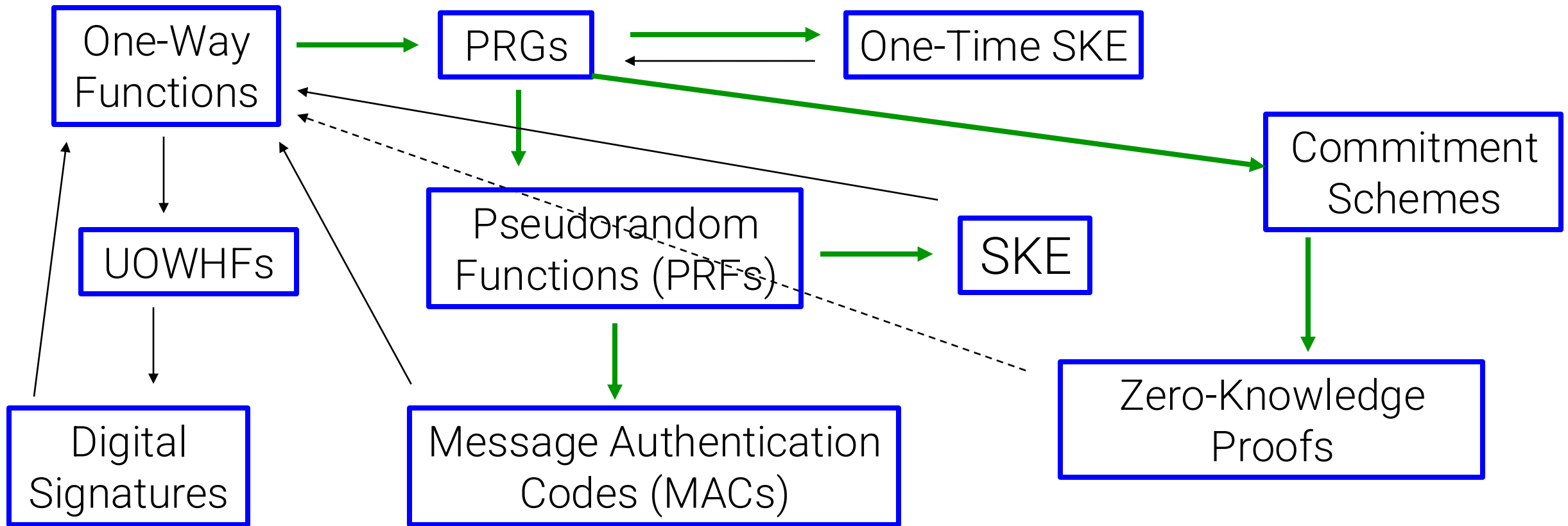
$$\Pr[A^{\text{Sign}(\textcolor{red}{k}, \cdot)}(1^\lambda) \rightarrow (m^*, \sigma^*): m^* \text{ was not queried and } \text{Verify}(\textcolor{red}{k}, m^*, \sigma^*) = 1] = \text{negl}(\lambda)]$$

How do we build MACs?



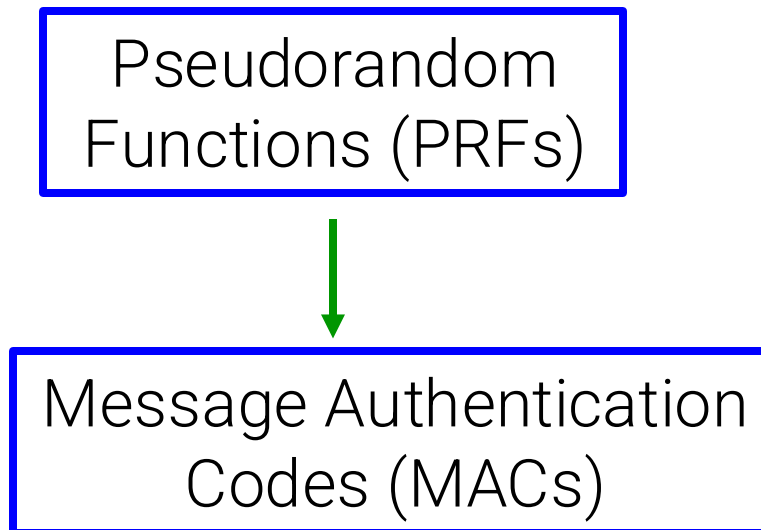
# Relationships between Cryptographic Primitives

**Theorem:** the following are **existentially equivalent** (we won't prove this in full)



# Constructing MACs

**Theorem:** If PRFs exist, then MACs exist.



# Constructing MACs

**Theorem:** If PRFs exist, then MACs exist.

**Proof:** Let  $F(\cdot, \cdot)$  denote a PRF family with output length  $\lambda$ . Then, define:

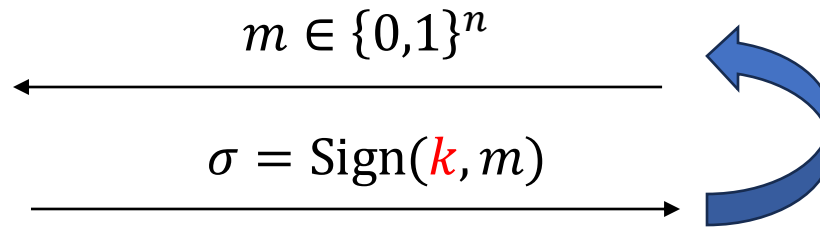
- $\text{Sign}(k, m) = F_k(m)$
- $\text{Verify}(k, m, \sigma) = 1$  if  $F_k(m) = \sigma$

**Notes:**

- Requires a PRF with long input length (**cannot** sign bit-by-bit).
- There are **more efficient/practical** constructions

# Security Proof

$\text{Sign}(k, \cdot)$

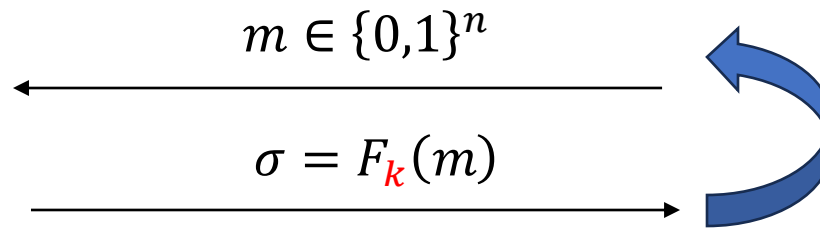
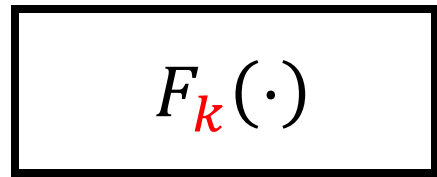


$(m^*, \sigma^*)$

Win if:

- $\text{Verify}(k, m^*, \sigma^*) = 1$ , and
- $m^*$  was not queried.

# Security Proof



$(m^*, \sigma^*)$

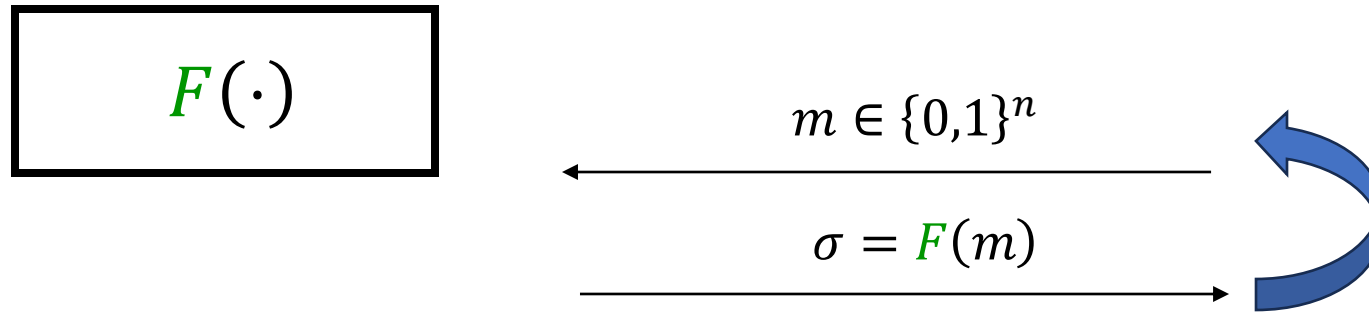
Want to show:

Win if:

$$\Pr[\text{Win}] = \text{negl}$$

- $\text{Verify}(k, m^*, \sigma^*) = 1$ , and
- $m^*$  was not queried.

# Security Proof



$(m^*, \sigma^*)$

By PRF security, suffices to show:

$$\Pr[\text{Win}] = \text{negl}$$

Win if:

But if  $F(m^*)$  was not queried, then  $F(m^*)$  is uniformly random and independent of what Adversary has seen!

- $\text{Verify}(k, m^*, \sigma^*) = 1$ , and
- $m^*$  was not queried.

$$\rightarrow \Pr[\text{Win}] = 2^{-\lambda}$$



Step 2: Chosen Ciphertext Security for Encryption

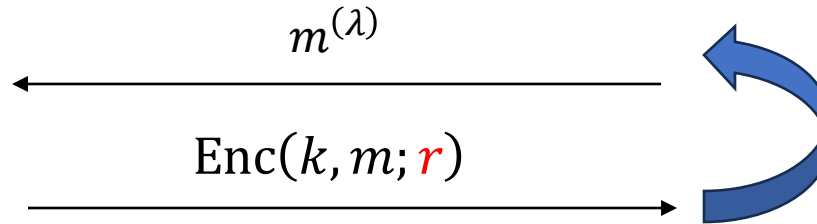
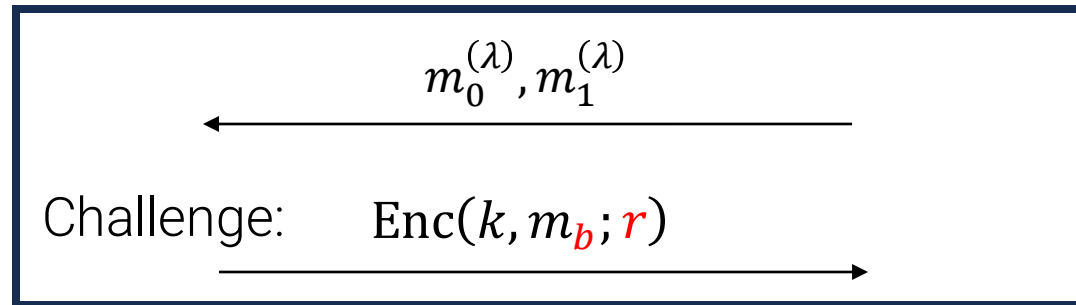
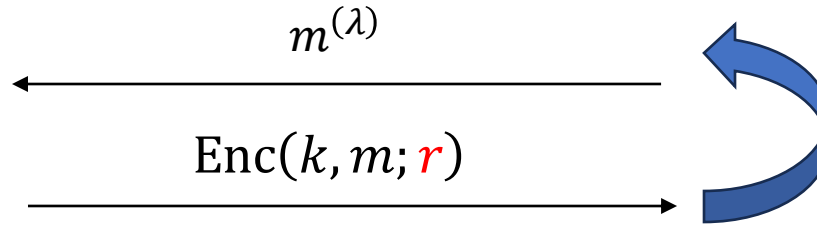
# CPA Security

Challenger/Honest Party



$k$

$b \leftarrow \{0,1\}$



Adversary



$b'$

Win if  $b' = b$

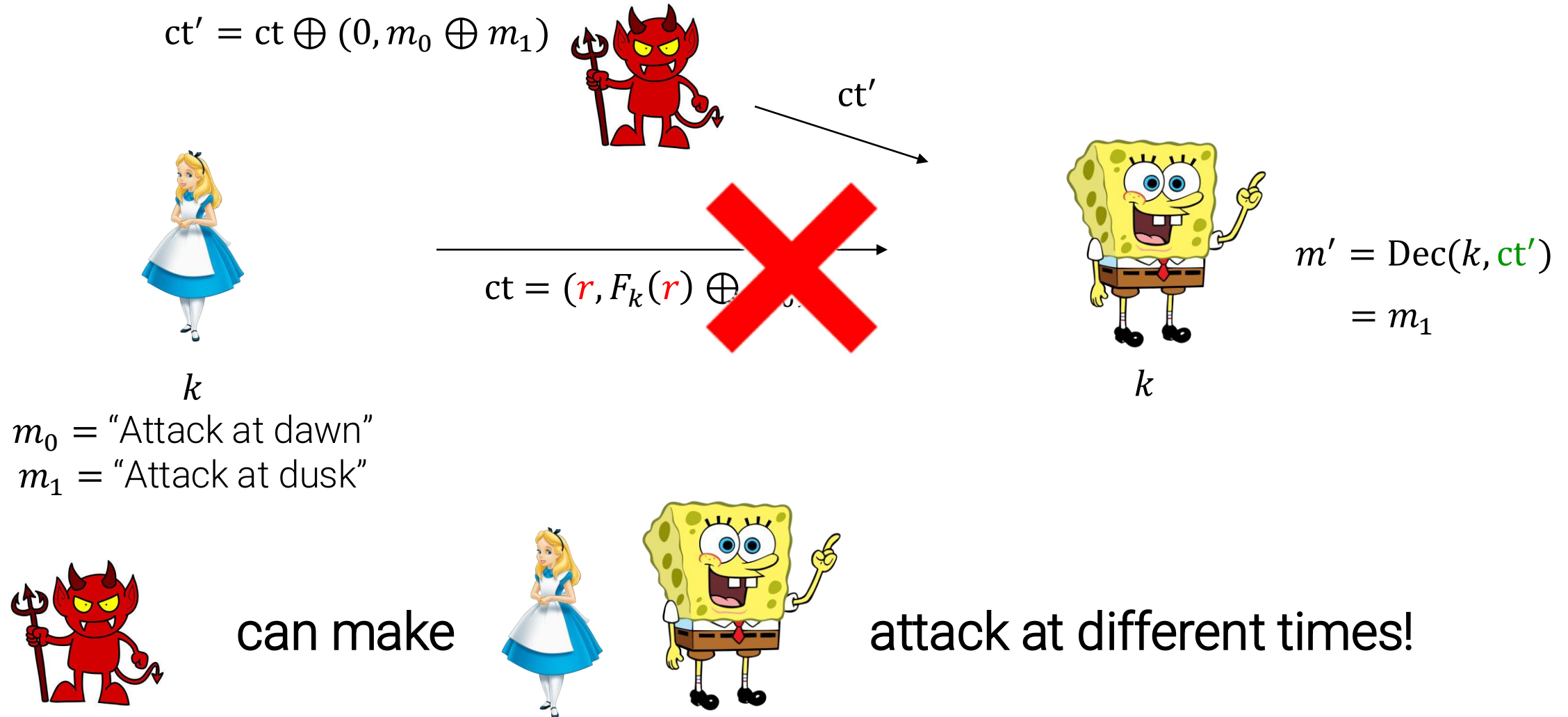
For all polynomial-time



$$\Pr[\text{Win}] \leq \frac{1}{2} + \text{negl}(\lambda)$$



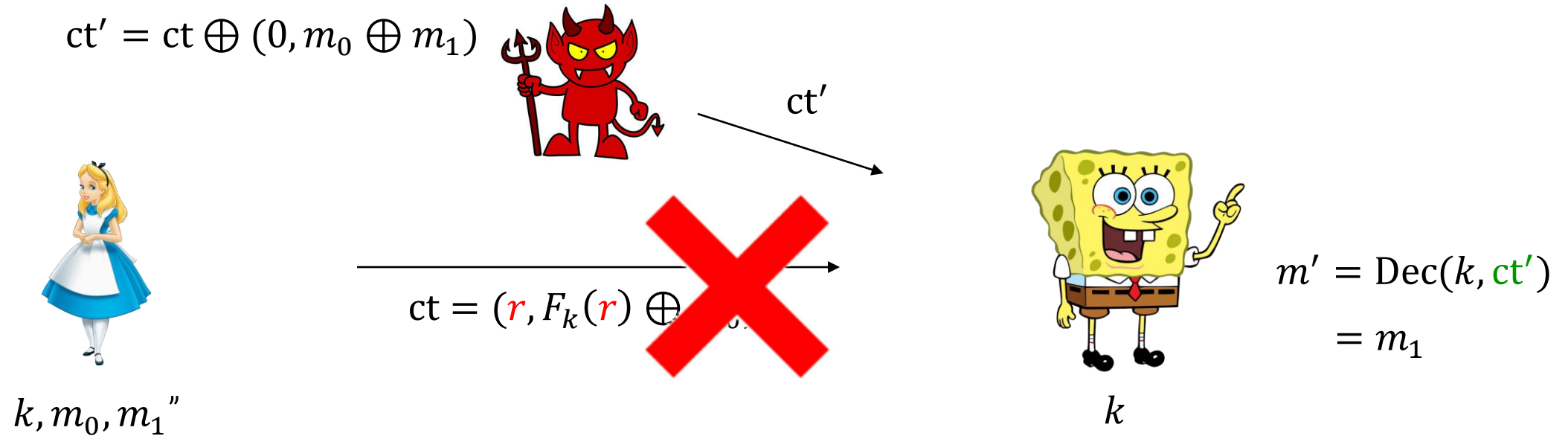
# Man in the Middle Attacks



What do MITM attacks have to do with **secrecy**?

**Strengthen** CPA-security to protect against MITM?

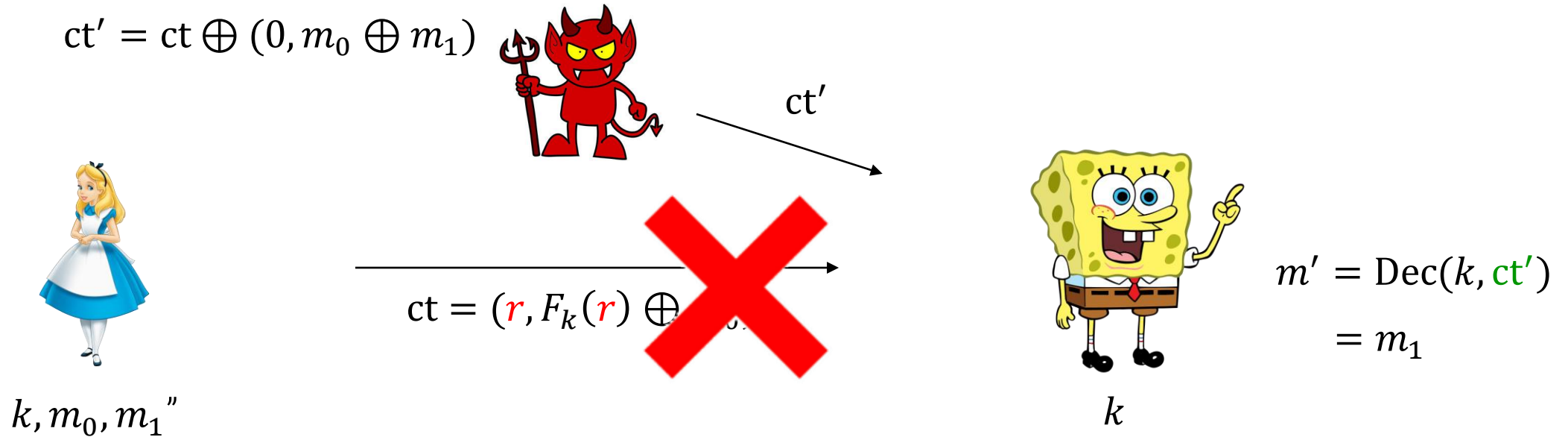
# Man in the Middle Attacks



Idea:  is influencing the world by sending  $ct'$  to Bob and observing how he behaves.

What happens depends on the value of  $\text{Dec}(k, ct')$ .

# Man in the Middle Attacks



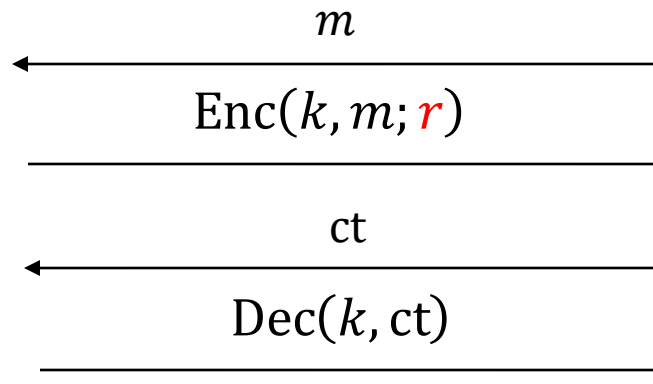
Idea:  is influencing the world by sending  $ct'$  to Bob and observing how he behaves.

Extremely cautious model: what if we just give  the value  $\text{Dec}(k, ct')$ ?

# Chosen Ciphertext Attack (CCA) Security

Challenger

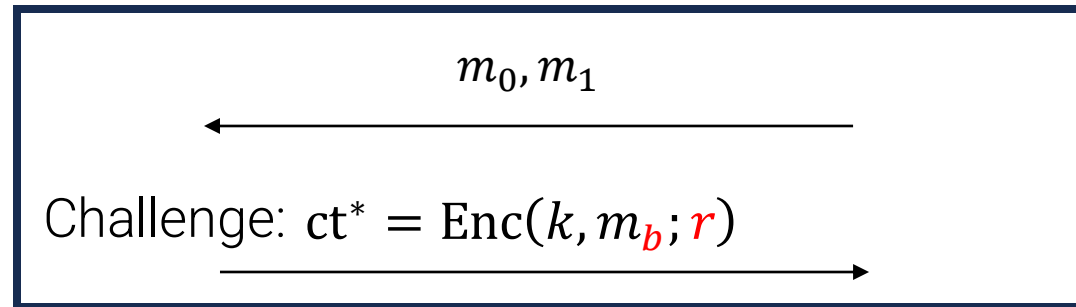
$k$



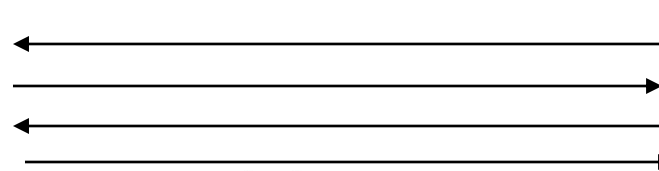
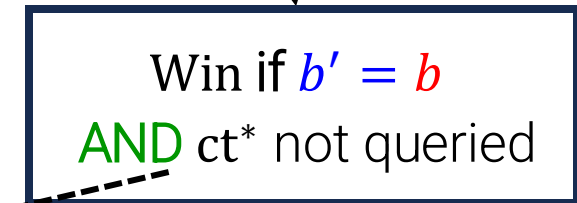
Adversary



$b \leftarrow \{0,1\}$



$b'$



For all polynomial-time



$$\Pr[\text{Win}] \leq \frac{1}{2} + \text{negl}(\lambda)$$

# Chosen Ciphertext Attack (CCA) Security

- Adversary has access to two oracles: Encryption and Decryption
- Adversary eventually submits  $(m_0, m_1)$  and gets back  $ct^* = \text{Enc}(m_b)$
- Afterwards, can still make queries, but cannot ask for a decryption of  $ct^*$
- Goal: guess  $b$

Claim: if SKE is CCA-secure, then it is **not subject to MITM attacks!**

- CCA-security is extremely powerful, ruling out many other kinds of attacks.

Building CCA-secure encryption



# Constructing CCA-Secure SKE

**Theorem:** If PRFs exist, then CCA-secure encryption exists!

**Proof:** Encrypt and then **Authenticate** (Sign)

- $\text{Enc}_{\text{CCA}}((k_1, k_2), m)$ :
  - Compute  $\text{ct} = \text{Enc}_{\text{CPA}}(k_1, m)$
  - Output  $\text{ct}_{\text{CCA}} = (\text{ct}, \text{Sign}(k_2, \text{ct}))$
- $\text{Dec}_{\text{CCA}}((k_1, k_2), \text{ct}, \sigma)$ :
  - If  $\text{Verify}(k_2, \text{ct}, \sigma) = 0$ , abort.
  - Output  $\text{Dec}_{\text{CPA}}(k_1, \text{ct})$

# Proof of Security (sketch)

Challenger

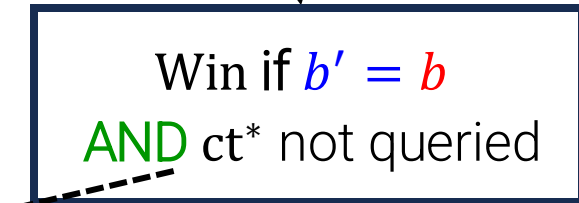
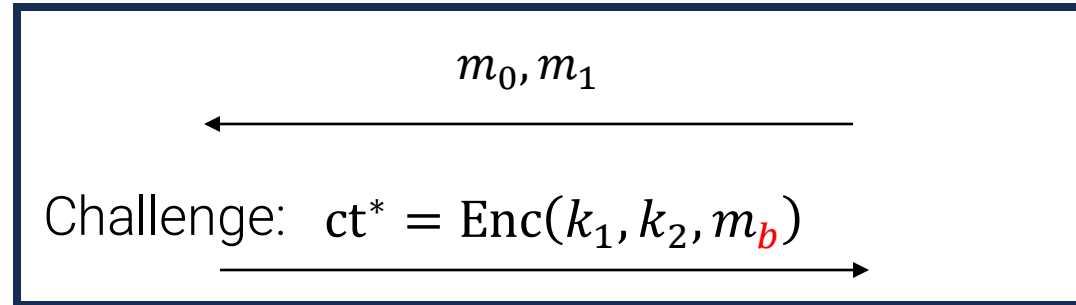
$k_1, k_2$



Adversary



$b \leftarrow \{0,1\}$



Idea: want to say that the decryption queries are “useless” to



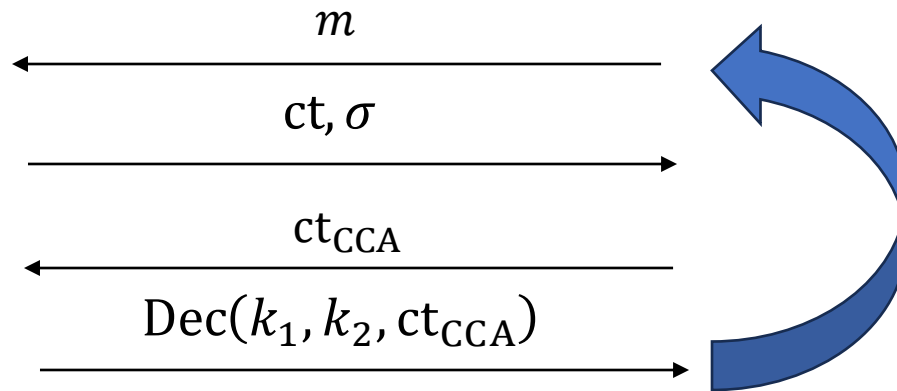
# Proof of Security (sketch)

Challenger

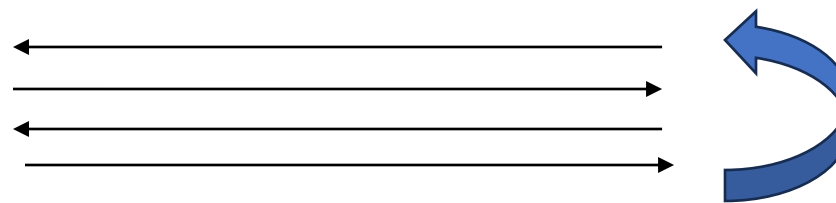
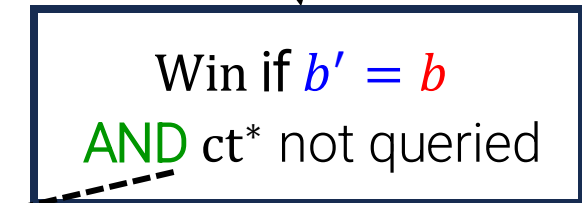
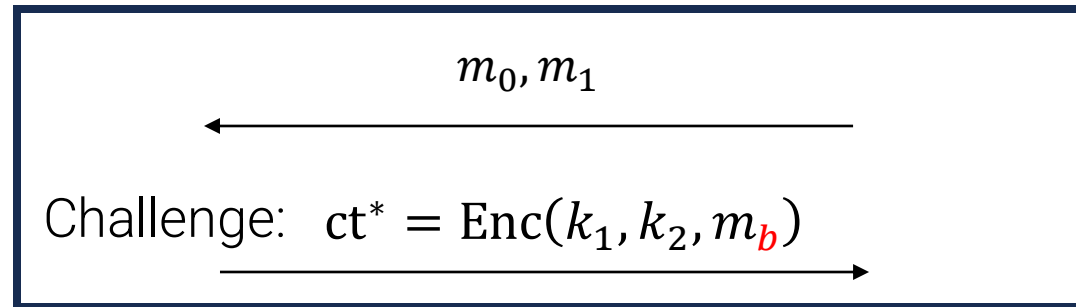
$k_1, k_2$



Adversary



$b \leftarrow \{0,1\}$



Either:  asked for a decryption that he got from , or he broke the MAC!

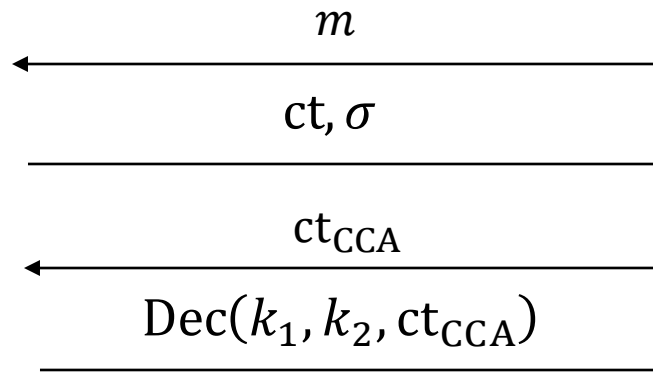
# Proof of Security (sketch)

Challenger

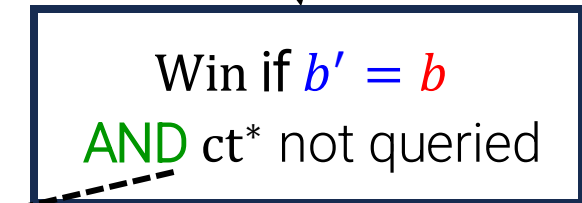
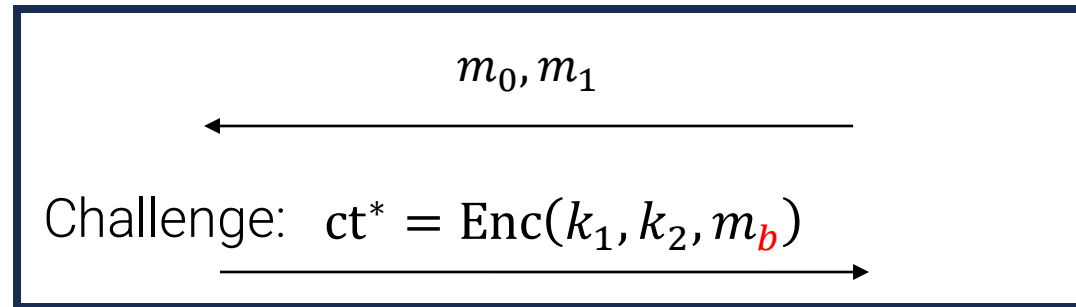
$k_1, k_2$



Adversary



$b \leftarrow \{0,1\}$



So: If MAC is secure,  could be used to break  $Enc_{CPA}$